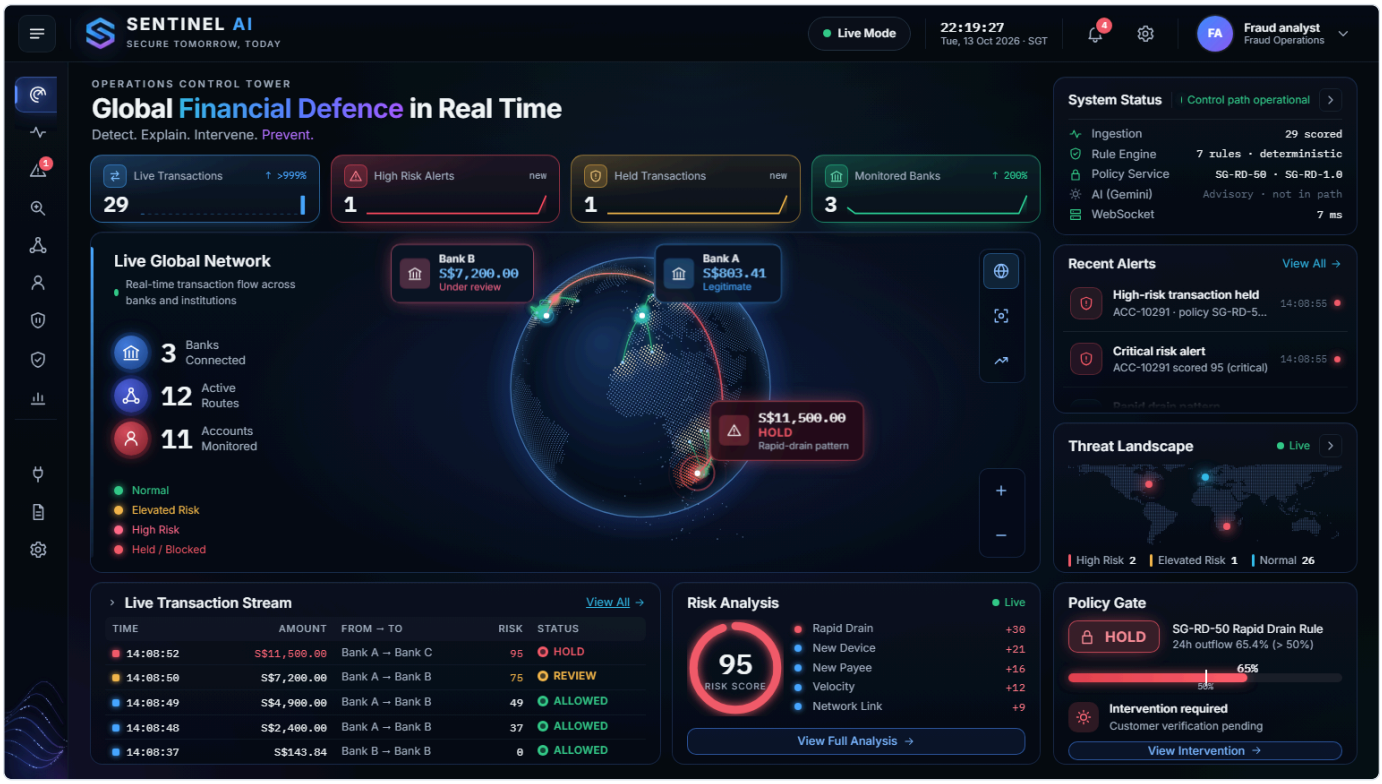
SENTINEL AI

Phase 1 Audit Corrections Report

Corrected statuses, the SG-RD-50 hold cascade, the evidence-grounded Gemini path in code, the investigation workspace, analyst intervention controls and runtime alignment. Checked against the v1.2 documents and ADR-007 and ADR-008.



Competition	AI Builder Cup 2026 · BFSI
Report date	13 October 2026 (freeze 15 October, submission 18 October)
Code state	Last commit `26ebe5d` plus the uncommitted changes described here. Nothing has been committed or pushed.
Verdict	**Not submission-ready.** The application is not deployed, and Gemini has not been called on Vertex AI.

1. Verdict and corrected statuses

> **Two entry requirements are still unmet.** The application has no deployment on Google Cloud and no public URL (C§2, M§12), and no Gemini call has been made on Vertex AI, so its behaviour has not been demonstrated (C§2, T§7). Both depend on a Google Cloud budget the owner has not yet approved. Every other statement in this report rests on tests run locally and against MongoDB Atlas.

Item	Previous report	Status now, with the reason
Rapid-drain detection (module 3)	Done (overstated: no cascade)	**Done** The post-threshold hold cascade is now implemented and covered by 12 tests (section 3). Until it was, the correct status was Partial.
Frontend tape (T§5)	Met (overstated: capped only)	**Met** The tape is now virtualised: only the rows in view plus an overscan are in the DOM, with a 200-row cap. Covered by 2 tests. Until then the correct status was Partial.
Security posture	Met (overstated)	**Prototype baseline controls implemented; cloud security verification and production security assessment pending.**

4 of 8 MVP modules done (1, 2, 3, 5)	**3 of 8** Partial (4, 6, 7)	**292** tests passing: 267 in verify (scenario included) + 25 on Atlas	**0** deployed URLs

2. Requirements implemented in this round

Requirement	What was built	Evidence
Post-threshold hold cascade (T§4, M§2, M§5.3)	Once a transfer breaches SG-RD-50, every later eligible outflow is held under `SG-RD-50_HOLD_CASCADE`, sharing the trigger's `holdUntil` and recording `cascadeOfTransactionId`. The STANDING, GIRO/eGIRO and designated-billing exclusions stay outside it. Only outflows that occurred after the trigger are reached. The cascade ends when the cooling period ends or when the customer verifies and the trigger is released. Cancellation and fraud confirmation do not end it. The score and contributions are unchanged. Decision in ADR-008.	`hold-cascade.api.spec.ts` (11); DEMO_TAKEOVER_01 cascade case; Atlas follow-on hold. Mutation check: with the cascade disabled, 9 of the 11 tests fail.
Intervention controls (M§5.3, module 4)	On Alerts & Cases, a Held transfers card lists the trigger and each cascaded hold. Each has *Release · customer verified*, *Cancel · customer request* and *Confirm fraud*, which records the analyst identity. Every action needs a second explicit confirmation and is recorded append-only by sentinel-core. A 409 conflict is reported plainly. There is no analyst release route.	`hold-actions.spec.ts` (4); screenshot 19
Evidence bundle (T§7, module 5)	Compiled from recorded data with the documented caps: last 50 transactions, 2 hops and 40 nodes. Synthetic identifiers only; no display reference. The contributions are exactly as recorded. MongoDB source and in-memory test source.	API test on DEMO_TAKEOVER_01; Atlas integration
Gemini explanation and case summary, in code (T§7, module 6)	Vertex AI REST `generateContent` with a structured-output response schema, the versioned system instruction verbatim, and model IDs from configuration only. Service-account credentials, no API key, per-tier timeouts. Schema validation, `sourceField` grounding with a count of dropped claims, rejection of any recommendation to release, one retry, then a deterministic fallback with a stated reason. Explanations are cached by `assessmentId` beside the contributions, never inside them.	Section 5; 25 tests across three suites
Investigation workspace (M§5.4)	Shows the account and decision, the deterministic attribution first, bundle counts, and the exact object sent to Gemini. Explain (fast tier) and Summarise case (deep tier) show grounded claims with their `sourceField`. A fallback is shown as a fallback. Includes the timeline.	`investigation-page.spec.ts` (4); screenshot 11
Tape virtualisation (T§5)	Fixed-height windowed rendering with spacer rows. No new dependency.	`transaction-tape.spec.ts` (2)
Control Tower refinement (owner's decisions)	The approved layout is kept. The top-bar Settings gear is restored; the analyst menu now holds profile actions only (Focus mode); Settings stays in the rail. One sidebar toggle at top left, the logo asset reused, no search. On the globe the held callout is placed first, and a callout that cannot fit without overlapping is hidden. Policy Gate labels a cascaded hold.	`shell.spec.ts`; screenshots 01, 03, 05, 06
Runtime alignment (ADR-007)	Node 24.18.0 everywhere; `@types/node` moved from 22.20.4 to 24.19.0 with a 20-line lockfile change.	Section 8
Design-system documentation	`docs/architecture/design-system.md`: colour tokens, typography, spacing and radii, elevation, icon family, motion and reduced motion, breakpoints and height tiers, accessibility, known discrepancies.	—

3. MVP modules — Master Document §7

Module	Status	Done means (M§7), and what exists	Gap

1 Transaction simulator	Done	Canonical events, seeded generators, DEMO_TAKEOVER_01, Pub/Sub publisher and direct push.	Noise generator. Replaying the scenario against the same database creates no new activity because the idempotency keys are deterministic.
2 Risk engine	Done	Seven pure rules; versioned decisions.	—
3 Rapid-drain detection	Done	S$50k / >50% / 24h gate with the three exclusions, and the hold cascade.	—
4 Intervention workflow	Partial	Automatic hold with decision trace; release after customer verification, cancellation and fraud confirmation in the UI; 24h auto-release; full audit trail; cascade as automatic kill-switch behaviour.	**Contact customer** action and an **analyst-initiated kill switch** are not built.
5 Investigation workspace	Done	Assembles and displays the evidence bundle.	Graph neighbourhood is empty unless network observations include the account.
6 Gemini explanation	Partial	Schema-validated, grounded case summary and explanation, fully implemented and tested with a scripted model.	**No Vertex AI call has been made.** Model IDs are not configured or verified.
7 Entity graph	Partial	Network ingest, edge evidence, two-hop flagged links in scoring, bundle neighbourhood.	Interactive graph screen, fund trace, and the graph API for the UI.
8 Case report	Not started	Shells only; `CaseService` is not implemented.	One-click report, edit, export.

4. Tests and results

Suite	Result
`npm run verify`: typecheck, ESLint with architecture boundaries, all unit/API tests, all production builds	Exit 0. Domain 7 · Rules 62 · Scenarios 13 · **Core 110** (73 before) · Stream 7 · Simulator 6 · **UI 62** (51 before) = **267 passed**. No Angular budget warnings.
`npm run test:integration` against MongoDB Atlas (throwaway database, dropped afterwards)	Core 23 · Stream 2 = **25 passed**. New coverage: evidence bundle read from Atlas, explanation cached without touching `contributions[]`, cascade hold on Atlas.
`npm run test:scenario` (DEMO_TAKEOVER_01 through the control path)	**15 passed** (a subset of Core 110). Scores 37 / 49 / 75 / 95, 65.4% drain, the six documented contributions summing to 95, and a cascade hold after the trigger is cancelled with those contributions unchanged.
New tests by area	Hold cascade 11 + 1 · intelligence validators and service 12 · Vertex gateway 5 · investigations API 8 · hold actions UI 4 · investigation page 4 · virtualised tape 2 · top-bar gear 1 · cascade label (builder) 1
`npm audit` (report only; nothing upgraded)	2 findings, both in **development tooling**: `shell-quote` 1.10.0 (critical, GHSA-pqg4-j6r4-53mv) via `npm-run-all2`, and `source-map-js` 1.2.1 (high, GHSA-68fv-2mgg-jv7q) via the Angular build and jsdom. `npm audit --omit=dev`: **0 vulnerabilities** in what ships. A non-forced `npm audit fix` is available; it was not applied.
Deployed-cloud smoke test	Not performed Nothing is deployed.

5. Deployed URLs and cloud evidence

None. No Google Cloud project was created, no billing was enabled, and nothing was built on Cloud Build or deployed to Cloud Run. Secret Manager and the real Pub/Sub push with OIDC on Google Cloud have not been exercised. This follows the owner's instruction not to create billable resources until a budget is approved.

What is ready for that step:

- Four Dockerfiles on `node:24.18.0-slim`, Cloud Run service definitions, and a `cloudbuild.yaml` that runs install, typecheck, lint, tests and the scenario before building images.
- Configuration for `GCP_PROJECT_ID`, `VERTEX_LOCATION`, `GEMINI_FAST_MODEL` and `GEMINI_DEEP_MODEL`.
- Pub/Sub OIDC verification in code; a forged token is rejected with 401 in tests.

6. Gemini: call, schema and fallback evidence

Behaviour (T§7)	Implementation	Evidence
Two tiers, model IDs from configuration	`ModelRouter.resolve(job)`. The explanation goes to the fast tier and the case summary to the deep tier. There are no model literals in code, and the browser holds no model ID or credential.	Router 3 tests; gateway routing test; UI scan
Vertex AI call	`POST https://{region}-aiplatform.googleapis.com/v1/projects/{p}/locations/{region}/publishers/google/models/{model}:generateContent` with a bearer token from application default credentials and no API key. Timeouts: fast tier 8 s; deep tier 15 s, its completion ceiling.	Gateway test asserts the URL, the header, no `key=` and a timeout signal
Structured output	`responseMimeType: application/json` and a `responseSchema` (CaseSummary: hypothesis ≤300 chars, confidence enum, ≤5 evidence items, recommendedActions, escalate).	Gateway test reads the schema in the request
System instruction	The five T§7 constraints are sent verbatim as `systemInstruction`. The bundle is one serialised typed object after a fixed, versioned job instruction.	Gateway test

Schema validation	Anything unparseable or off-contract is rejected: wrong enum, a hypothesis over 300 characters, more than five items, a non-boolean `escalate`.	Validator tests
`sourceField` grounding	A claim survives only if its path exists in the bundle that was sent. Prototype paths do not count. A summary left with no grounded claim counts as invalid. The number of dropped claims is shown to the analyst.	Unit tests; API test drops `customer.callNotes`
Never recommends release	Any recommended action that says to release is rejected; a negation such as "do not release" passes.	Unit and API tests
Retry once, then fallback	At most two calls. The outcome is `FALLBACK` with the reason `INVALID_RESPONSE`, `MODEL_UNAVAILABLE` or `MODEL_NOT_CONFIGURED`; the last is not retried. The deterministic attribution is always on screen.	Service tests; API tests; screenshot 11
Cache by assessmentId	Stored once in `assessments.explanation`; a second request makes no model call. A fallback is never cached.	Unit, API and Atlas tests
Gemini outside the decision path	ESLint import boundaries keep AI out of the eight control-path modules. An outage leaves the hold and score unchanged.	Lint; API outage test

> **Not demonstrated:** a real Gemini response. The tests use a scripted model, which proves what the server does with any answer but not that Vertex AI answers. The model IDs required by T§7 have not been checked against the Vertex AI model list. Locally the workspace shows the honest *"No Gemini model is configured"* fallback.

7. Remaining MVP gaps, in priority order

1. **Deploy to Cloud Run** from Cloud Build, with a public URL, the Atlas URI in Secret Manager, the real Pub/Sub push with OIDC, and a deployed smoke test. Needs budget approval.
2. **Real Gemini on Vertex AI:** configure and verify the model IDs, run the case summary and explanation on DEMO_TAKEOVER_01, and pre-warm the cached explanation before the pitch.
3. **Module 4:** the Contact customer action and an analyst-initiated kill switch.
4. **Module 7:** the interactive entity-graph screen and fund trace; `MongoGraphRepository.neighbourhood` and `traceFunds` are not implemented.
5. **Module 8:** the case report, with `CaseService` open, escalate, report and export.
6. **Demo robustness:** a re-run of DEMO_TAKEOVER_01 against the same database produces no new activity, so a run-scoped scenario code or a database reset is needed. The simulator's instant timeline crashed once on Windows (libuv assertion); the real-time timeline ran cleanly.
7. Gemini-outage toggle, the in-app performance panel, control-path latency instrumentation, and the noise generator.
8. The submission package: README run-through from a clean clone, architecture diagram, proposal, 3-minute video, and the `submission-v1` tag.

8. Runtime version consistency (ADR-007)

Place	Value	Aligned
Local runtime / `.nvmrc`	v24.18.0 / `24.18.0`	Yes
Root `engines.node` (+ `engine-strict=true`) and lockfile root entry	`>=24.0.0 <25.0.0`	Yes
`@types/node` in core, stream and simulator	`~24.19.0`, locked at 24.19.0 (no 24.18.x types release exists). It was `~22.20.4`.	Yes
Cloud Build (all Node steps)	`node:24.18.0-slim`	Yes
Dockerfiles: core, stream, simulator (build and runtime); UI (build; runtime is nginx)	`node:24.18.0-slim`	Yes
`npm run doctor`	Fails unless the Node major is 24	Yes
CI templates	No GitHub Actions; Cloud Build is the CI	—

Incident, now resolved: `npm install` ran while the local demo held `esbuild.exe` open. npm then rewrote `package-lock.json` without 84 platform-specific optional packages, which would have broken `npm ci` on Cloud Build's Linux runners. The lockfile was restored and only the `@types/node` entries were changed (20 lines). Your running `npm run demo` was stopped and `node_modules` reinstalled with `npm ci`. ADR-007 records the precaution.

9. Security

Status: Prototype baseline controls implemented; cloud security verification and production security assessment pending.

Checks passed	Not performed, or known gaps
• Working-tree secret scan: no connection string with credentials, Google API key or private key; `.env` is git-ignored; no service-account or credential file is tracked. • Report and logs print no URI or password. • No model ID, endpoint or credential in the browser bundle. • Vertex calls use service-account tokens, never API keys (tested). • AI cannot reach the control path (lint boundary); the model cannot recommend release (validator). • Pub/Sub push OIDC verification rejects forged tokens (tested locally). • CORS limited to the UI origin. • Append-only interventions; analyst identity recorded on fraud confirmation; no analyst release route. • All data synthetic and tokenised; the bundle excludes display references. • Production dependency audit: 0 vulnerabilities.	• **No authentication or authorisation** on the core REST APIs, including the intervention actions, and no analyst login. The analyst identity is a single labelled demo value. • No Cloud IAM, service-account least-privilege, Secret Manager or VPC review: nothing is deployed. • OIDC push verification not exercised on Google Cloud. • No penetration test, threat model review, rate limiting or WAF. • Atlas network access list and database-user scope not reviewed for production. • Two development-tooling audit findings left unfixed, as instructed.

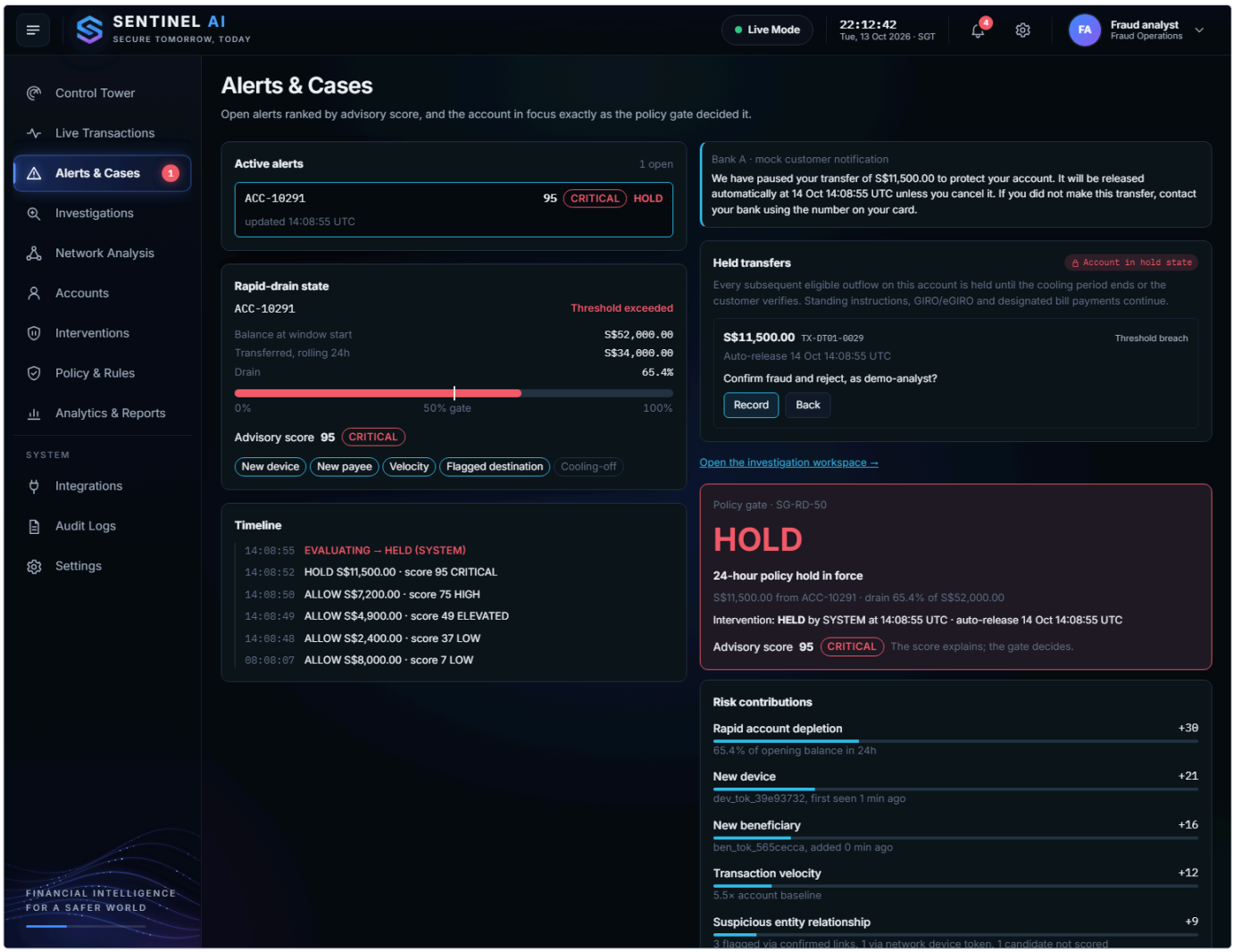
10. Design discrepancies

- The Control Tower counters follow the approved visual design (live transactions, high-risk alerts, held, monitored banks), not the four listed in M§5.1.
- Several Control Tower gradients use literal colours close to, but not exactly, the design tokens (listed in `design-system.md` §8).
- At 1366×640 Recent Alerts has room for only one partly visible item, and the globe shows only the callouts that fit without overlap. The held-transfer callout always shows.
- The Policy Gate meter's percentage label and the 50% marker label touch when the drain is near the line.
- In demo time the hold lasts 24 seconds, so the Held transfers card empties quickly. The screenshots here were taken without compression in a throwaway database (since dropped), so the demo-time label does not appear in them.

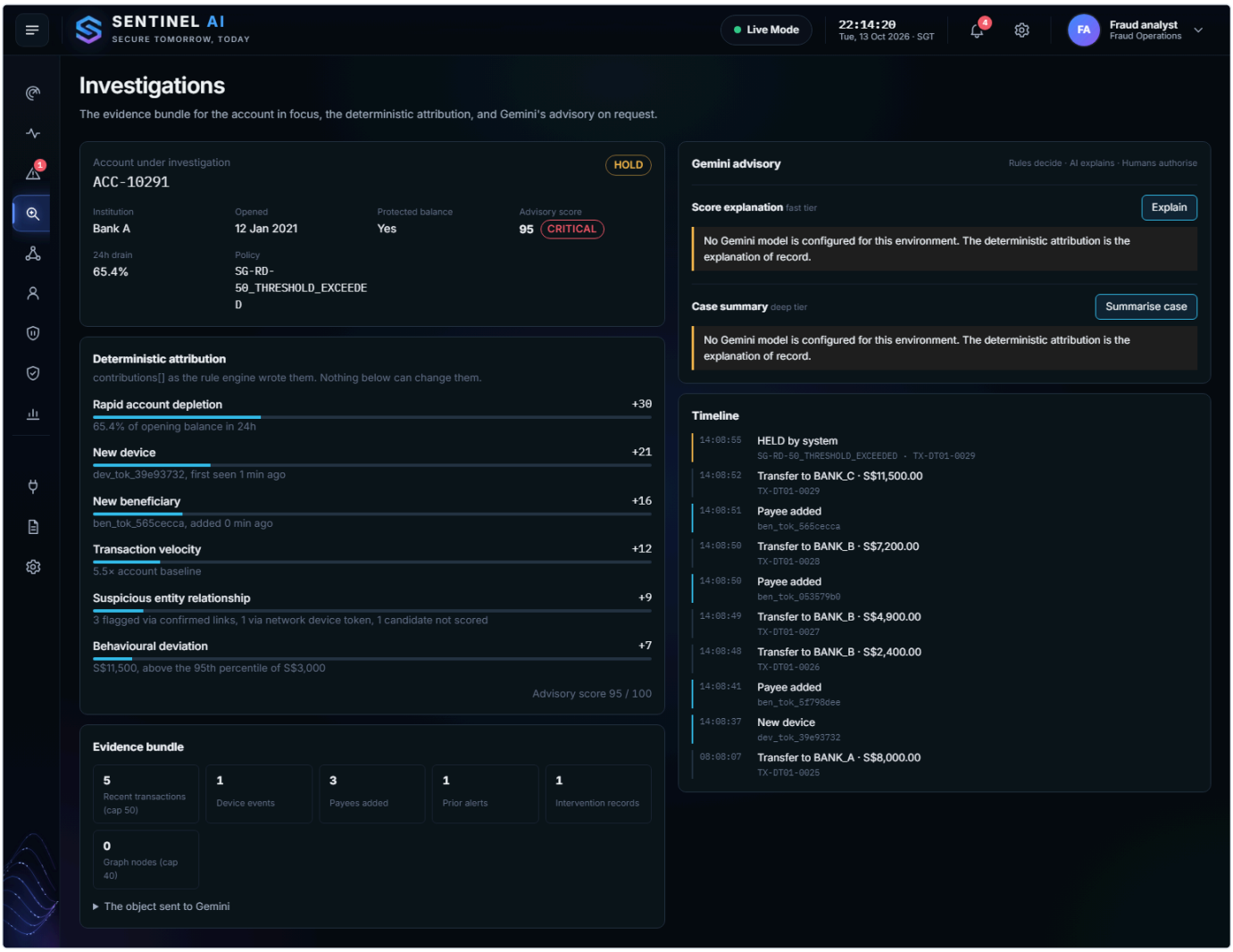
11. Screens



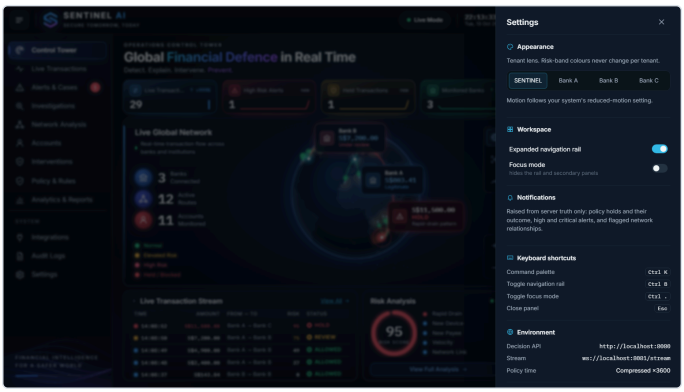
1366×640: the whole Control Tower, no page scroll; the held-transfer callout is placed first and never covered.



Alerts & Cases: the account in hold state, the Held transfers card, and the second-step confirmation of a fraud rejection under the analyst identity. Nothing is recorded until *Record* is pressed.



Investigation workspace: the decision, the deterministic attribution, bundle counts and the object sent to Gemini, the timeline, and the advisory panel showing the honest fallback, because no Gemini model is configured locally.



Settings opened from the restored top-bar gear.



Analyst menu: profile actions only.

All data shown is synthetic. Bank A, Bank B and Bank C are fictional participating institutions. No real bank or COSMIC integration is claimed.